UNIVERSIDAD PERUANA UNIÓN

Actividad Autónoma N.º 10

Expiración de sesión JWT, almacenamiento seguro y autorización por permisos

Estudiante	Quispe Huamán, Jorge Armando
Proyecto	PharmaMobil - cliente Kotlin Multiplatform
Rama	feature/auth-jwt-quispe
Enlace a la rama	https://github.com/123456jor/pharmaMobile-/tree/feature/auth-jwt-quispe
Fecha	15/10/2026
Entorno	Windows 11 · Android Studio · AVD Pixel 8 Pro API 37.1 · PharmaSoft perfil dev · Oracle Free en Docker

Alcance

Pruebas reales en Android y backend local PharmaSoft. iOS no fue evaluado por indicación del usuario y por no disponer de macOS/Xcode.

1. Resumen de ejecución

Se ejecutaron seis escenarios de autenticación, tres verificaciones de almacenamiento, cuatro efectos de cierre de sesión y una matriz de permisos de 18 celdas. Se incluyen las seis capturas reales de Postman y las capturas de Android obtenidas con adb. Las salidas reales del archivo cifrado y Logcat se capturaron abiertas en Bloc de notas, sin alterar el contenido.

Hallazgo principal

El evento de sesión podía perderse por usar tryEmit. El cambio a emit garantiza que un 401 por expiración o invalidez llegue al observador y produzca cierre de sesión y navegación al login.

Control de restauración

Comprobación	Resultado
Configuración JWT	app.jwt.expiracion-minutos: 60
Usuarios	admin=true, almacen=true, vendedor=true
Login posterior	HTTP 200 · 3600 segundos
Fecha de control	2026-10-15 18:13:30 -05:00

Método y trazabilidad

• Backend Spring Boot en http://localhost:8080 y Oracle Free en Docker.

• Android usó http://10.0.2.2:8080 desde Pixel 8 Pro.

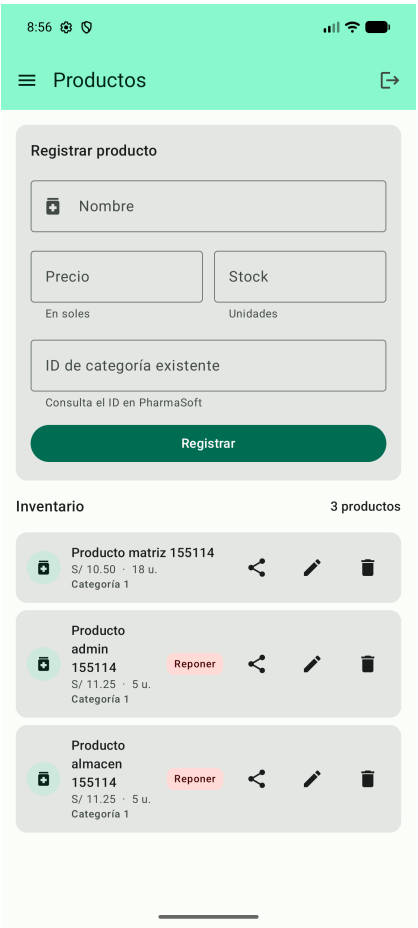
• Los escenarios 2 y 6 alteraron temporalmente configuración/estado y fueron restaurados.

• Cada escenario incluye la reacción de Android y la respuesta real de Postman. Las repeticiones para capturar el servidor se registran con su propia fecha y hora.

2.1 A-01 · Token válido

Fecha y hora	2026-10-15 15:50:28 -05:00
Plataforma	Android
Pasos	Login admin; GET /api/v1/productos con Bearer JWT mediante el cliente real y respaldo HTTP.
HTTP	200
message literal	Sin mensaje de error; se recibió el listado de productos.
Qué vio el usuario	Pantalla Productos con inventario cargado.

```
EVIDENCIA REAL - ESCENARIO 1: TOKEN VALIDO
Ejecutado: 2026-10-15 15:50:28 -05:00
Peticion: GET http://localhost:8080/api/v1/productos
Autenticacion: Bearer JWT de admin (contenido omitido)
HTTP: 200 OK
Resultado: listado recibido; cantidad observada: 1
Conclusion: el servidor acepto el JWT valido y autorizo la consulta.
```



Captura real del emulador Android

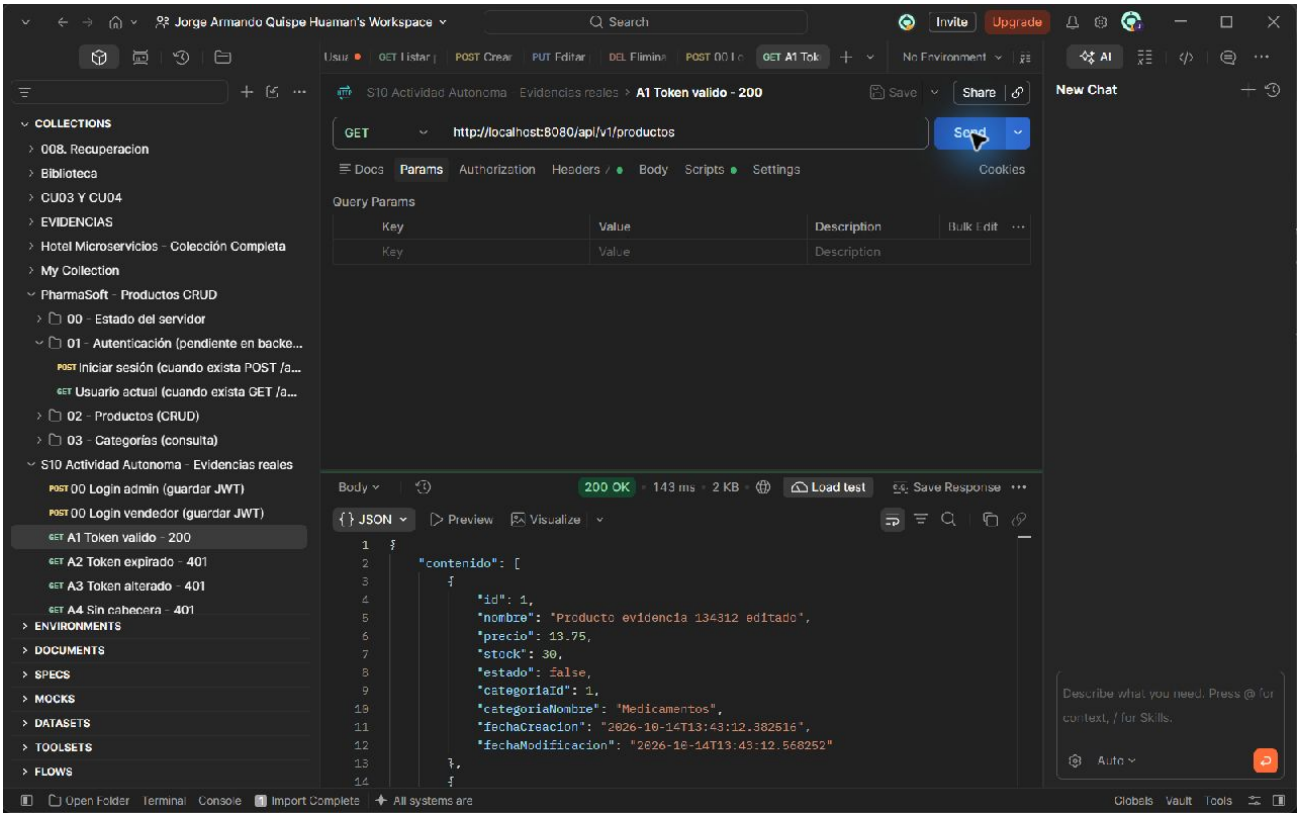
Conclusión

Un JWT vigente permite acceder al catálogo protegido y la interfaz presenta los datos.

2.1 Evidencia de servidor · Token válido

Captura original de Postman tras ejecutar GET /api/v1/productos. El código HTTP y el message provienen de la respuesta real del backend; la pestaña visible evita mostrar el JWT.

Repetición capturada: 2026-10-15 17:58:51 -05:00



Resultado observado

HTTP 200 · Sin mensaje de error; se recibió el listado de productos.

2.2 A-02 · Token expirado

Fecha y hora	2026-10-15 15:53:47 -05:00
Plataforma	Android
Pasos	Expiración temporal a 1 minuto; login; espera 65 s; operación CRUD; restauración a 60 minutos.
HTTP	401
message literal	El token ha expirado. Inicie sesión nuevamente
Qué vio el usuario	Login con aviso: Tu sesión expiró. Inicia sesión nuevamente.
Detección	Sí. Tras corregir SesionManager, el 401 limpia sesión y navega al login.

```
EVIDENCIA REAL - ESCENARIO 2: TOKEN EXPIRADO

Ejecutado: 2026-10-15 15:53:47 -05:00

Preparacion: app.jwt.expiracion-minutos=1; login; espera de
65 segundos

Peticion: GET http://localhost:8080/api/v1/productos

HTTP: 401 Unauthorized

message: El token ha expirado. Inicie sesión nuevamente

path: /api/v1/productos

Restauracion: expiracion=60; login nuevo
expiraEnSegundos=3600
```



Captura real del emulador Android

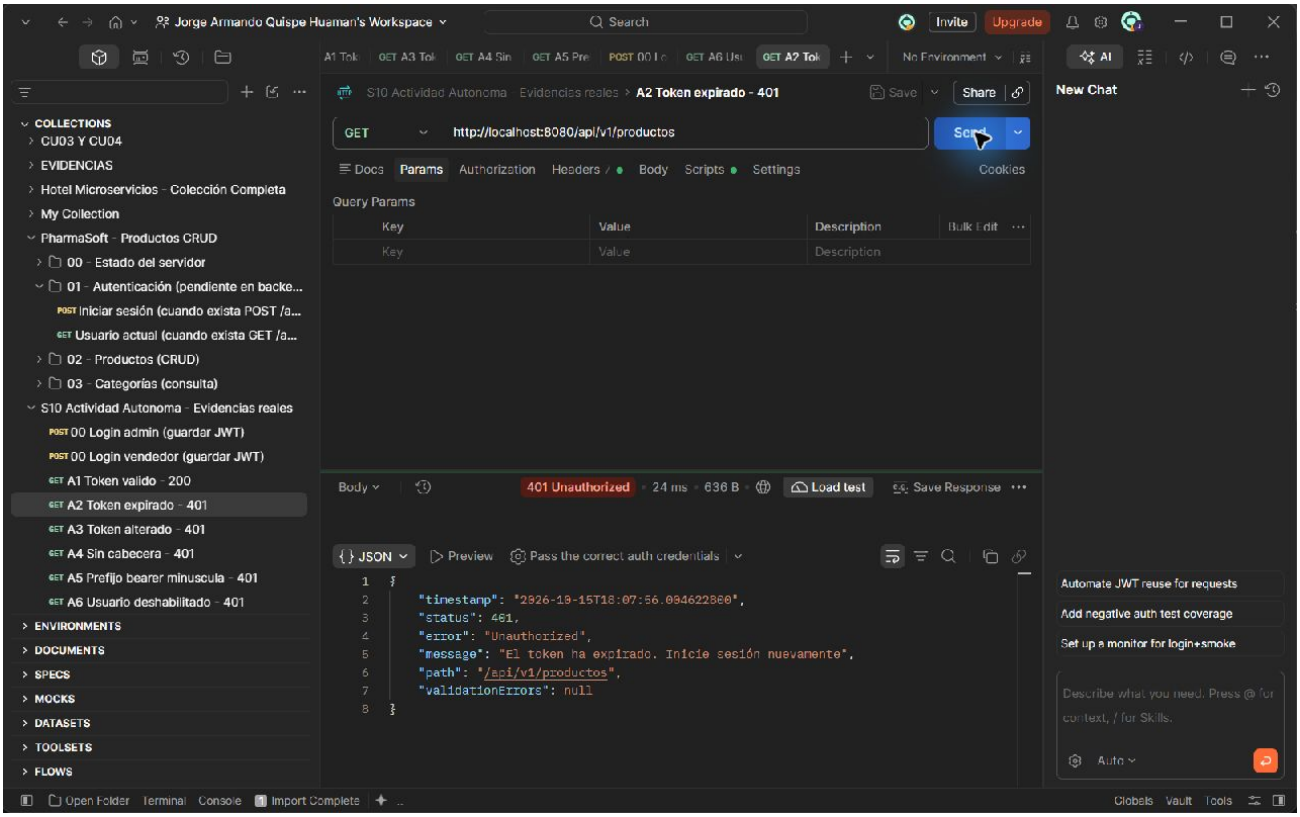
Conclusión

La sesión vencida ya no deja al usuario dentro de una pantalla protegida.

2.2 Evidencia de servidor · Token expirado

Captura original de Postman tras ejecutar GET /api/v1/productos. El código HTTP y el message provienen de la respuesta real del backend; la pestaña visible evita mostrar el JWT.

Repetición capturada: 2026-10-15 18:08:11 -05:00



Resultado observado

HTTP 401 · El token ha expirado. Inicie sesión nuevamente

2.3 A-03 · Token alterado

Fecha y hora	2026-10-15 16:10:53 -05:00
Plataforma	Android
Pasos	Login; broadcast debug cambia un carácter de la firma; reinicio de la app; petición protegida.
HTTP	401
message literal	El token no es válido
Qué vio el usuario	Login con aviso de sesión expirada; el JWT completo nunca se registró.
Detección	Sí. La app invalidó la sesión y volvió al login.

```
EVIDENCIA REAL - ESCENARIO 3: TOKEN ALTERADO

Ejecutado: 2026-10-15 15:50:28 -05:00

Preparacion: se cambio un caracter de la firma; JWT completo
omitido

Peticion: GET http://localhost:8080/api/v1/productos

HTTP: 401 Unauthorized

message: El token no es válido

Conclusion: la firma modificada fue rechazada por el
servidor.
```



Captura real del emulador Android

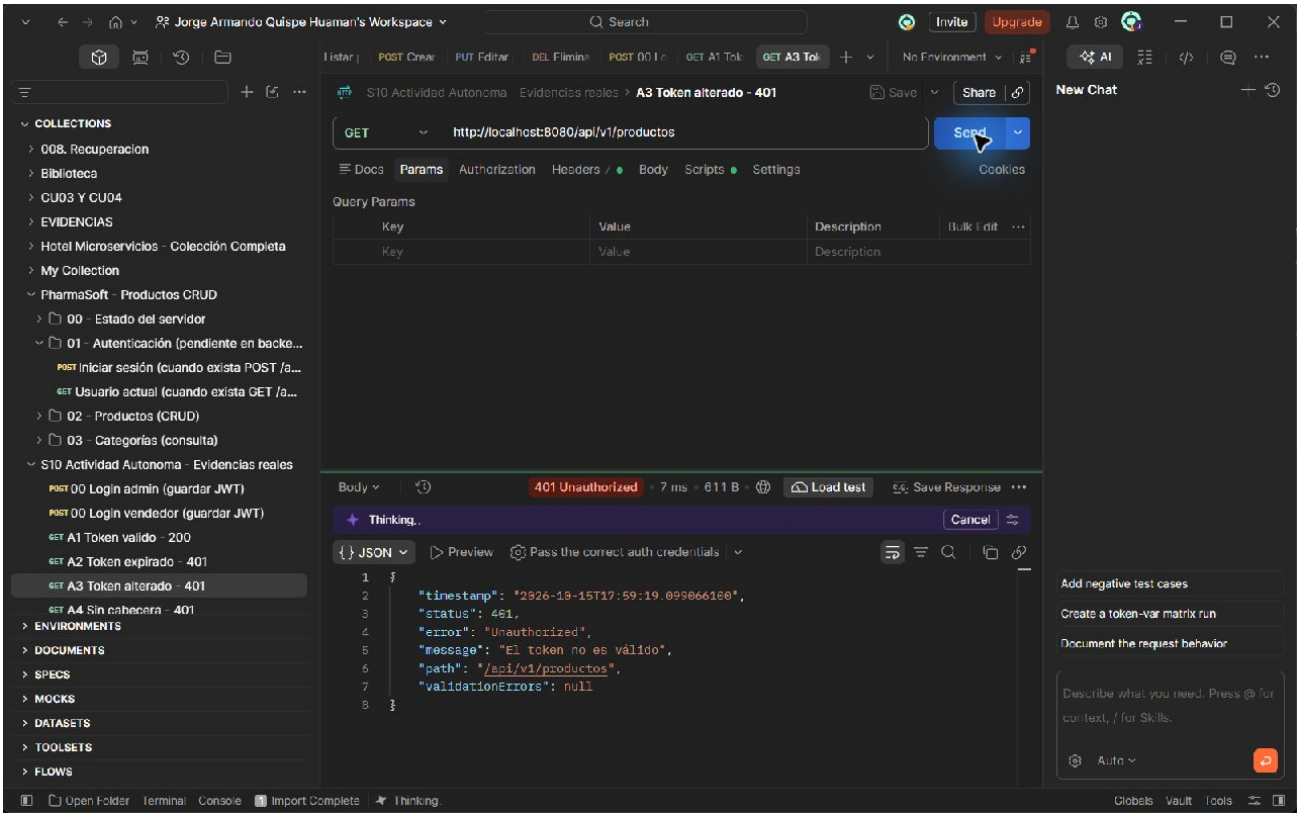
Conclusión

La validación de firma rechaza manipulaciones y el cliente elimina la sesión inválida.

2.3 Evidencia de servidor · Token alterado

Captura original de Postman tras ejecutar GET /api/v1/productos. El código HTTP y el message provienen de la respuesta real del backend; la pestaña visible evita mostrar el JWT.

Repetición capturada: 2026-10-15 17:59:42 -05:00



Resultado observado

HTTP 401 · El token no es válido

2.4 A-04 · Sin cabecera Authorization

Fecha y hora	2026-10-15 16:18:18 -05:00
Plataforma	Android + PowerShell HTTP
Pasos	Cerrar sesión; GET /api/v1/productos sin cabecera Authorization; observar login limpio.
HTTP	401
message literal	Debe iniciar sesión para acceder a este recurso
Qué vio el usuario	Formulario de login vacío, sin datos protegidos visibles.

```
EVIDENCIA REAL - ESCENARIO 4: SIN CABECERA
Ejecutado: 2026-10-15 15:50:28 -05:00
Peticion: GET http://localhost:8080/api/v1/productos
Authorization: cabecera no enviada
HTTP: 401 Unauthorized
message: Debe iniciar sesión para acceder a este recurso
Conclusion: el recurso protegido rechazo la peticion anonima.
```



Captura real del emulador Android

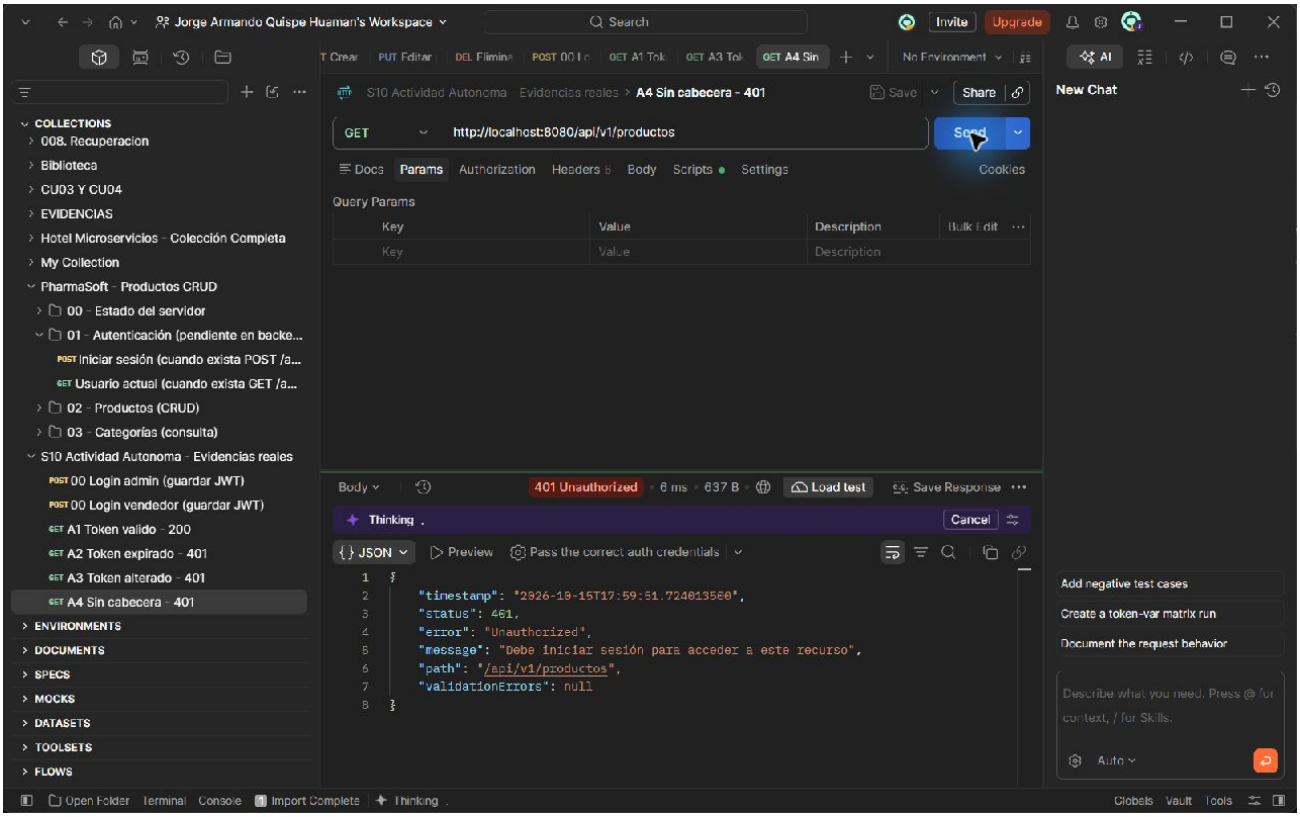
Conclusión

Sin credenciales el backend bloquea el recurso y la aplicación permanece fuera de sesión.

2.4 Evidencia de servidor · Sin cabecera Authorization

Captura original de Postman tras ejecutar GET /api/v1/productos. El código HTTP y el message provienen de la respuesta real del backend; la pestaña visible evita mostrar el JWT.

Repetición capturada: 2026-10-15 18:00:09 -05:00



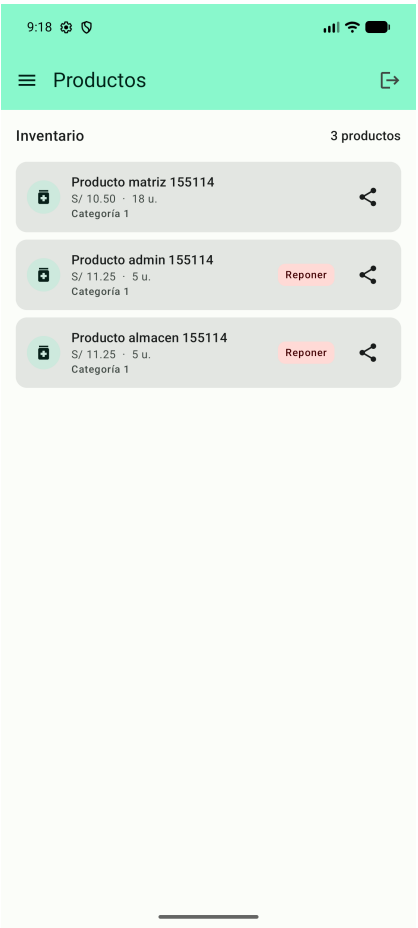
Resultado observado

HTTP 401 · Debe iniciar sesión para acceder a este recurso

2.5 A-05 · Prefijo bearer minúsculo

Fecha y hora	2026-10-15 16:18:18 -05:00
Plataforma	Android + PowerShell HTTP
Pasos	Login vendedor para obtener JWT; GET productos con Authorization: bearer [JWT OMITIDO].
HTTP	401
message literal	Debe iniciar sesión para acceder a este recurso
Qué vio el usuario	La sesión normal de la app siguió en Productos; la solicitud auxiliar fue rechazada de forma aislada.

```
EVIDENCIA REAL - ESCENARIO 5: PREFIJO INCORRECTO
Ejecutado: 2026-10-15 15:50:28 -05:00
Peticion: GET http://localhost:8080/api/v1/productos
Authorization: bearer [JWT OMITIDO] (b minuscula)
HTTP: 401 Unauthorized
message: Debe iniciar sesión para acceder a este recurso
Conclusion: el servidor ignoro el esquema no reconocido y
trato la peticion como anonima.
```



Captura real del emulador Android

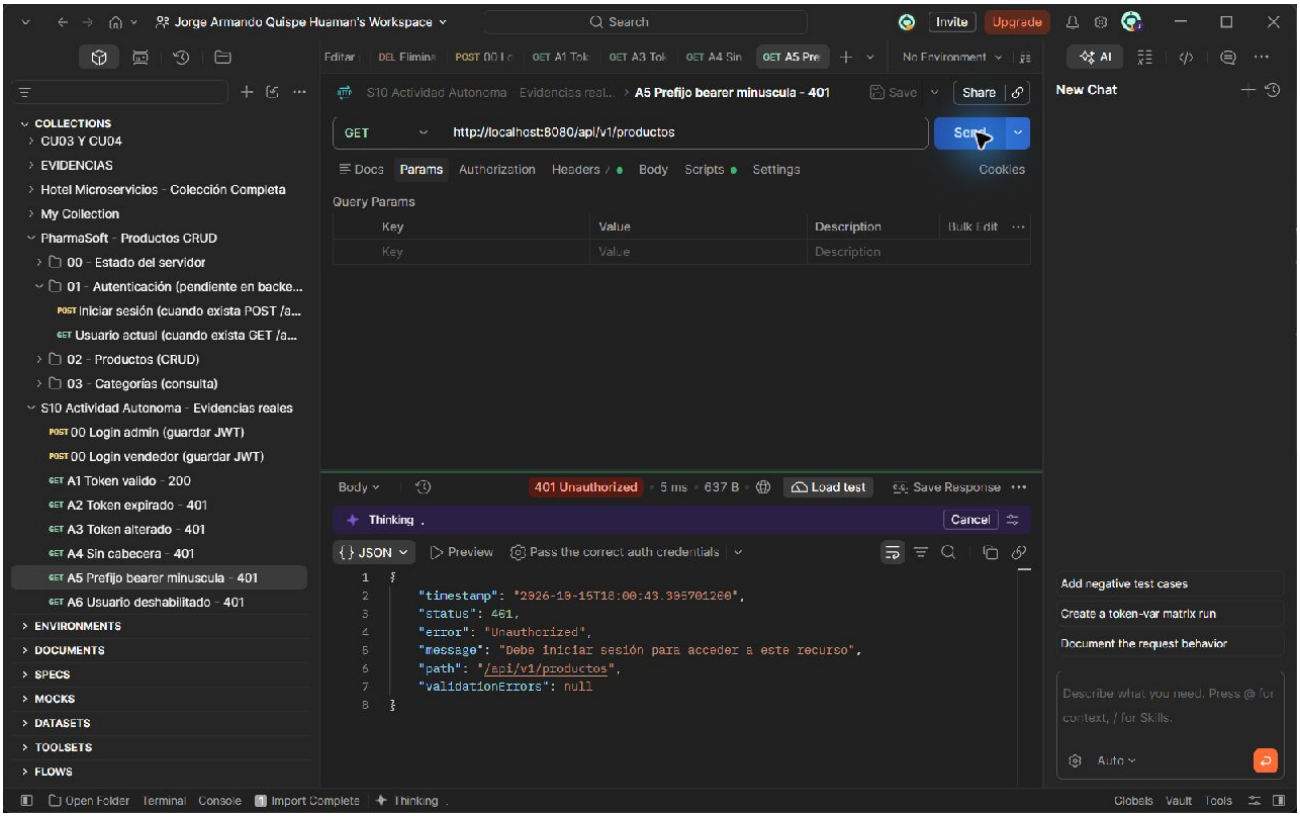
Conclusión

El esquema escrito en minúscula no se reconoce y la solicitud se trata como anónima.

2.5 Evidencia de servidor · Prefijo bearer minúsculo

Captura original de Postman tras ejecutar GET /api/v1/productos. El código HTTP y el message provienen de la respuesta real del backend; la pestaña visible evita mostrar el JWT.

Repetición capturada: 2026-10-15 18:00:58 -05:00



Resultado observado

HTTP 401 · Debe iniciar sesión para acceder a este recurso

2.6 A-06 · Usuario deshabilitado

Fecha y hora	2026-10-15 15:55:42 -05:00
Plataforma	Android + Oracle
Pasos	Login vendedor; UPDATE usuarios SET estado=false; operación protegida; restaurar estado=true y repetir login.
HTTP	401
message literal	El usuario está deshabilitado
Qué vio el usuario	Login con aviso de sesión expirada.
Detección	Sí. La app limpió la sesión abierta y navegó al login.

```
EVIDENCIA REAL - ESCENARIO 6: USUARIO DESHABILITADO

Ejecutado: 2026-10-15 15:55:42 -05:00

Usuario: vendedor; estado durante la prueba: false

Peticion: GET http://localhost:8080/api/v1/productos con
sesion abierta

HTTP: 401 Unauthorized

message: El usuario está deshabilitado

Restauracion: vendedor=true; login posterior HTTP 200;
expiraEnSegundos=3600
```



Captura real del emulador Android

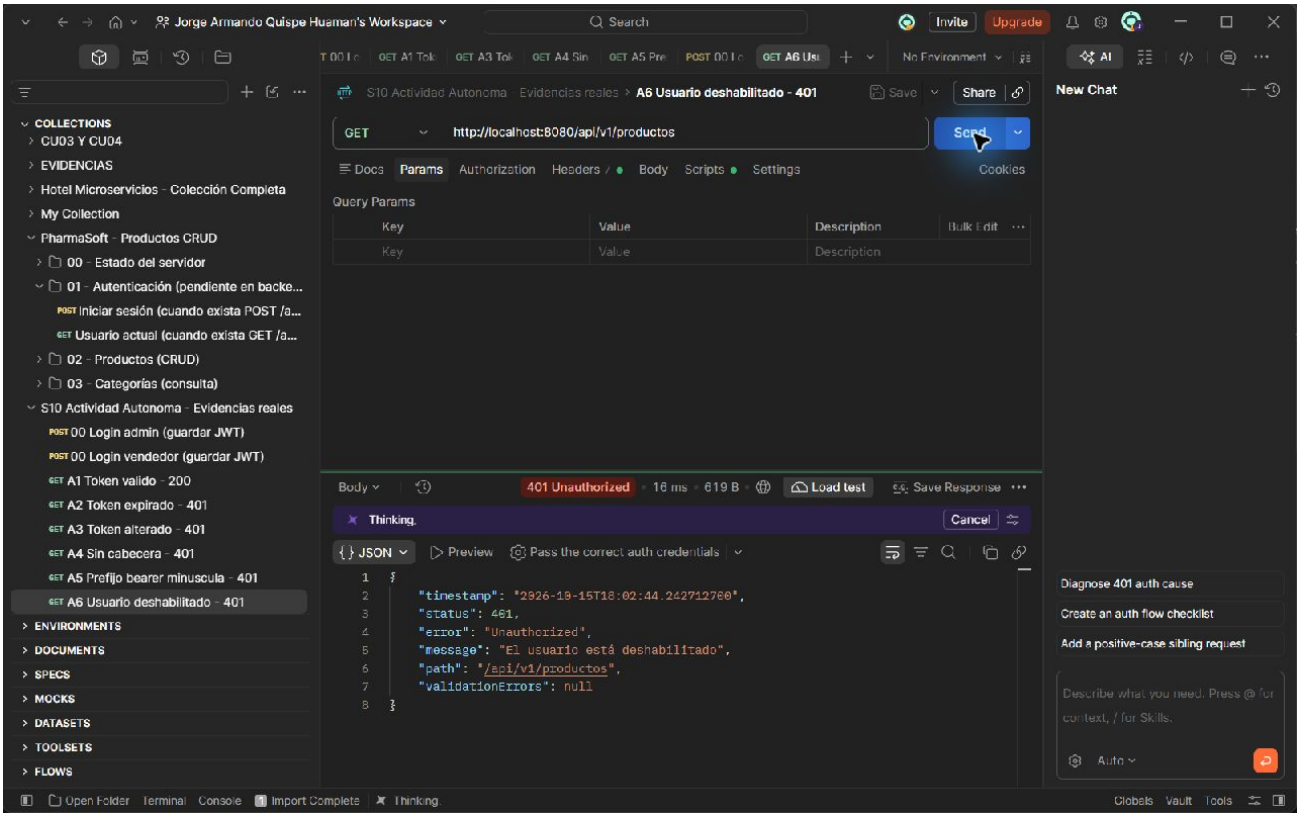
Conclusión

La deshabilitación en la base de datos revoca una sesión ya abierta en la siguiente petición.

2.6 Evidencia de servidor · Usuario deshabilitado

Captura original de Postman tras ejecutar GET /api/v1/productos. El código HTTP y el message provienen de la respuesta real del backend; la pestaña visible evita mostrar el JWT.

Repetición capturada: 2026-10-15 18:02:57 -05:00

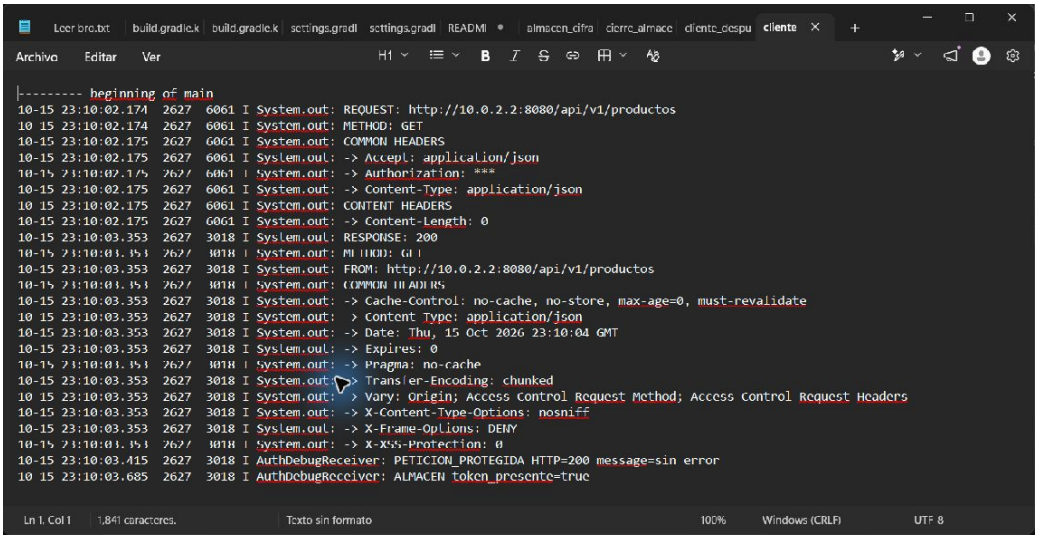


Resultado observado

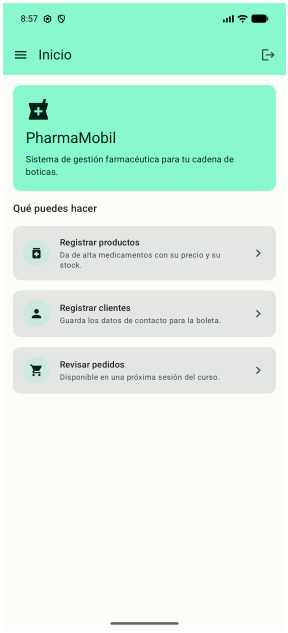
HTTP 401 · El usuario está deshabilitado

3. Almacenamiento seguro

Prueba	Cómo se verificó	Resultado observado
Archivo cifrado	adb shell run-as pe.edu.upeu.pharmamobil cat shared_prefs/sesion_segura.xml y conteo de eyJ.	XML con clave y valor cifrados; conteo eyJ = 0. Captura del archivo extraído con adb run-as y mostrado en Bloc de notas, sin modificar el XML.
Log saneado	adb logcat filtrado por Authorization y búsqueda de fragmento JWT.	Logcat real: Authorization: ***; GET 200. La salida se extrajo con adb y se capturó abierta en Bloc de notas.
Persistencia	force-stop del paquete y reapertura desde launcher.	La sesión persistió y se abrió Inicio sin pedir credenciales.
iOS	No ejecutado	No se dispuso de macOS/Xcode; iOS quedó fuera del alcance indicado por el usuario y no se fabricó evidencia.



Salida real de Logcat abierta en Bloc de notas: Authorization: *** y GET 200.

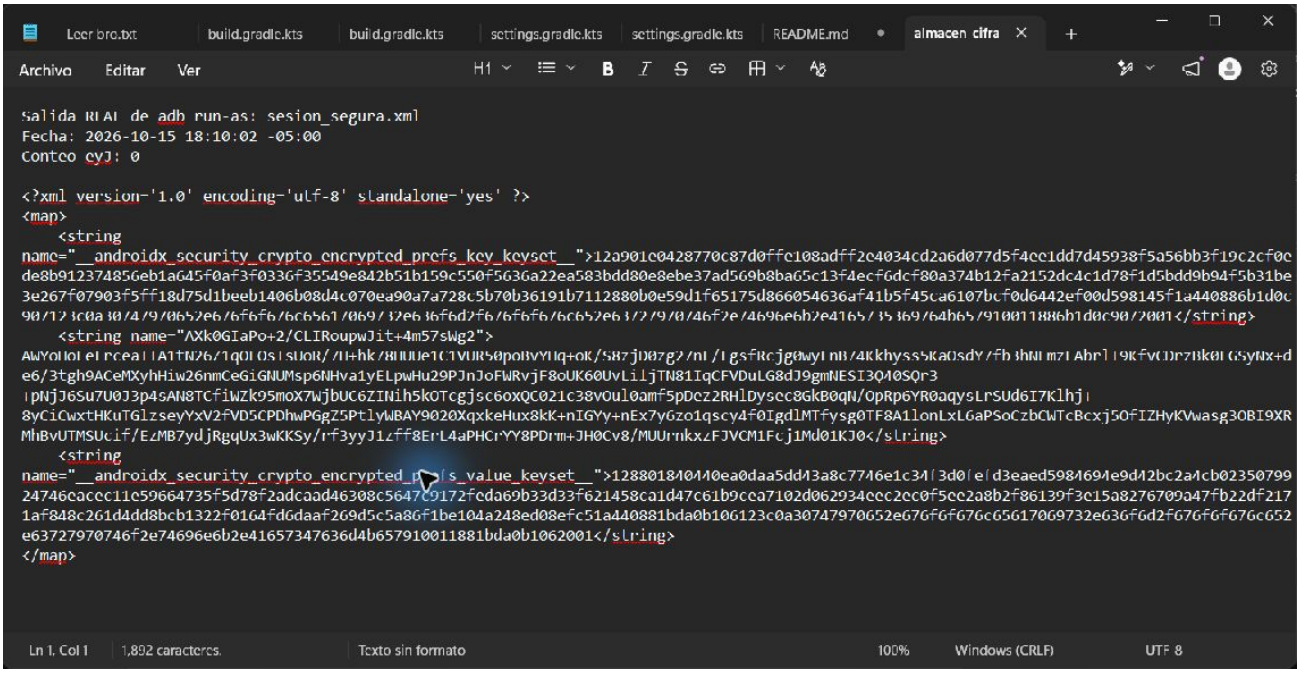


Sesión persistente

Tras iniciar sesión, se forzó el cierre del proceso con adb am force-stop y se volvió a abrir la app. La captura muestra que entró a Inicio sin solicitar credenciales.

3.1 Archivo cifrado en Android

Se extrajo sesion_segura.xml con adb shell run-as pe.edu.upeu.pharmamobil cat shared_prefs/sesion_segura.xml. La salida original se abrió en Bloc de notas y se capturó. Se ve una clave y un valor cifrados, además de los keysets internos de AndroidX Security. La búsqueda eyJ devolvió cero coincidencias.



Captura real de la salida de ADB; no es una pantalla simulada ni una captura de Device Explorer.

Observación

El token no se conserva en texto claro. Al cerrar sesión desaparece la entrada cifrada del token y permanecen únicamente los keysets del mecanismo de cifrado.

4. Cierre de sesión completo

Efecto	Estado	Observación
Token borrado del almacén	OK	Tras Cerrar sesión, el archivo cifrado no contenía el JWT; longitud observada: 1143 bytes.
Caché HTTP limpiada	OK	Prueba real en proceso Android PID 2627: antes del logout GET 200 con Authorization saneada; después, sin reiniciar, GET 401 sin Authorization; message: Debe iniciar sesión para acceder a este recurso; token_presente=false. Refuerzo: 2 pruebas host, 0 fallos.
Interfaz limpia	OK	El login volvió con usuario y contraseña vacíos y sin listas protegidas.
Back stack protegido	OK	KEYCODE_BACK mostró la pantalla de inicio de Android y no regresó al contenido autenticado. Se reabrió la app tras el logout y permaneció en login sin restaurar credenciales.



Login sin datos anteriores

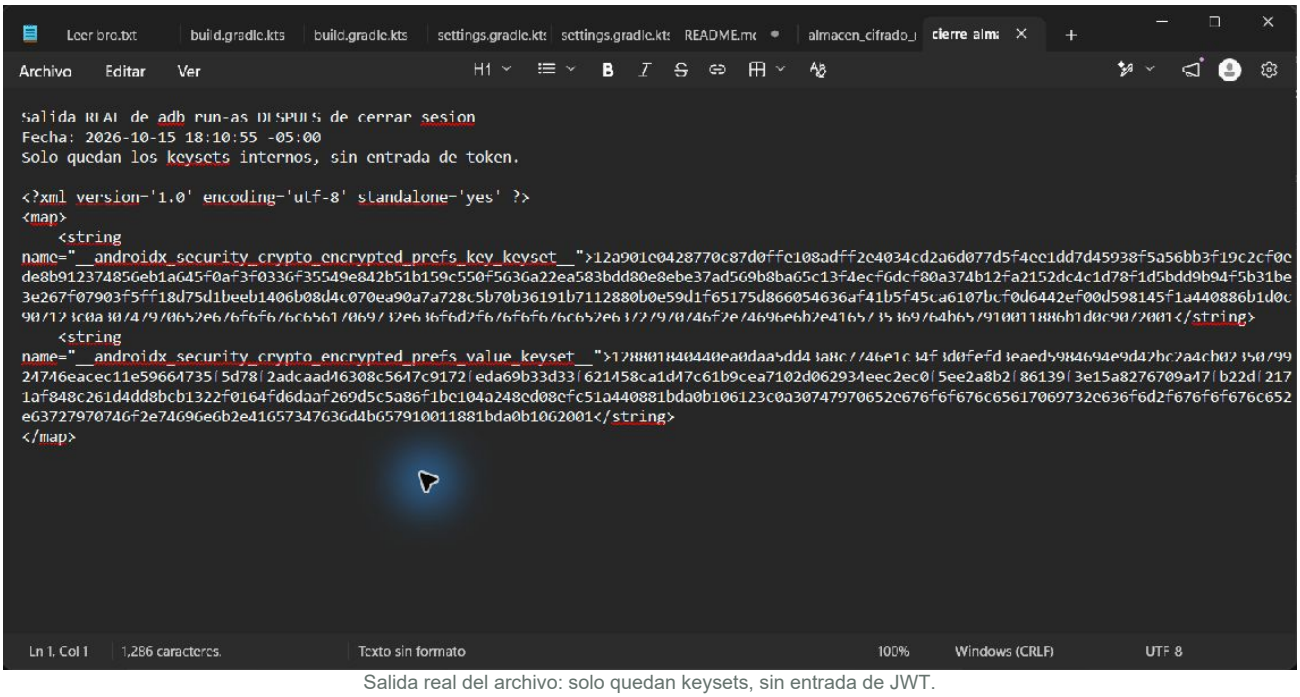


Atrás no vuelve a la app autenticada

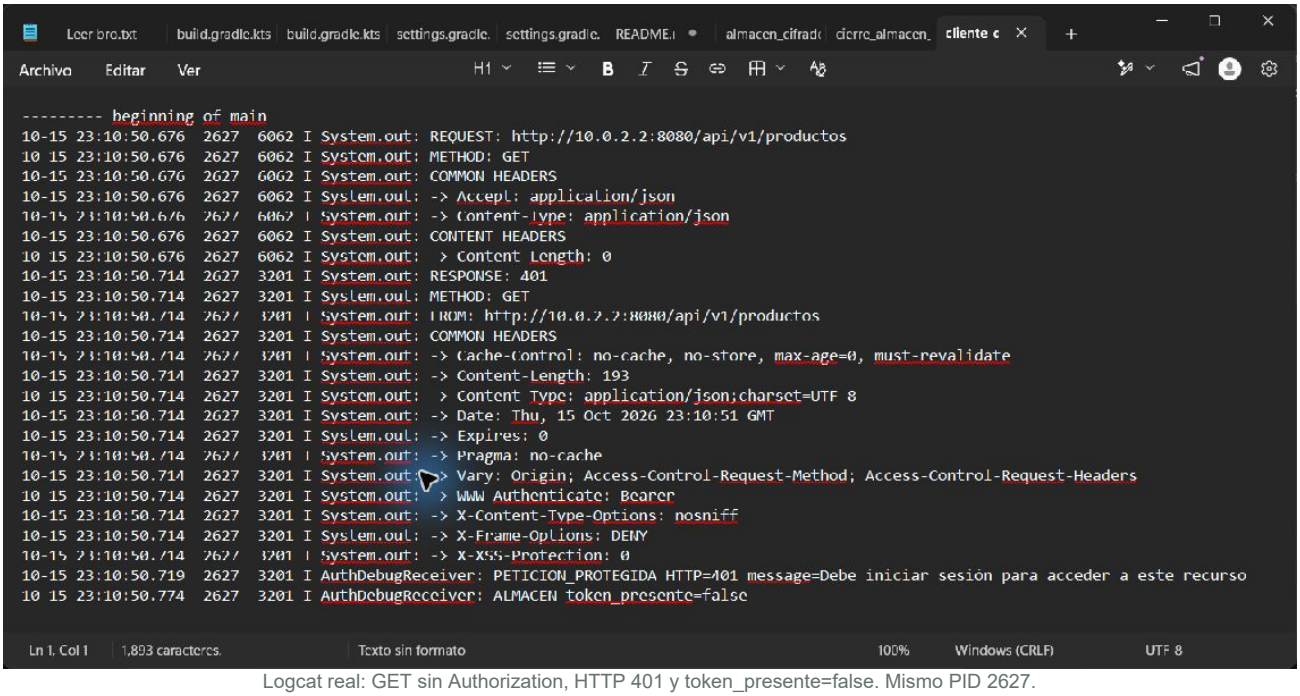
Prueba de caché

Verificación real: el proceso Android PID 2627 hizo una petición 200 con sesión; después del logout, el mismo cliente y proceso hizo una petición sin Authorization y recibió 401. Refuerzo: AuthRepositorioRestTest, 2 pruebas, 0 fallos.

4.1 Almacén y cliente después del logout



Salida real del archivo: solo quedan keysets, sin entrada de JWT.



Logcat real: GET sin Authorization, HTTP 401 y token_presente=false. Mismo PID 2627.

Las dos salidas de ADB se abrieron en Bloc de notas para tomar estas capturas. La reapertura posterior permaneció en el login; evidencia adicional: A_cierre_reapertura_login.png.

5. Matriz de permisos

Operación	admin	vendedor	almacen
Listar productos	HTTP 200 · ofrecida	HTTP 200 · ofrecida	HTTP 200 · ofrecida
Registrar producto	HTTP 201 · ofrecida	HTTP 403 · oculta	HTTP 201 · ofrecida
Listar clientes	HTTP 200 · ofrecida	HTTP 200 · ofrecida	HTTP 403 · oculta
Registrar venta	HTTP 201 · no existe en la app	HTTP 201 · no existe en la app	HTTP 403 · oculta
Ver reportes	HTTP 200 · no existe en la app	HTTP 403 · no existe en la app	HTTP 403 · no existe en la app
Consultar /auth/me	HTTP 200 · uso interno	HTTP 200 · uso interno	HTTP 200 · uso interno

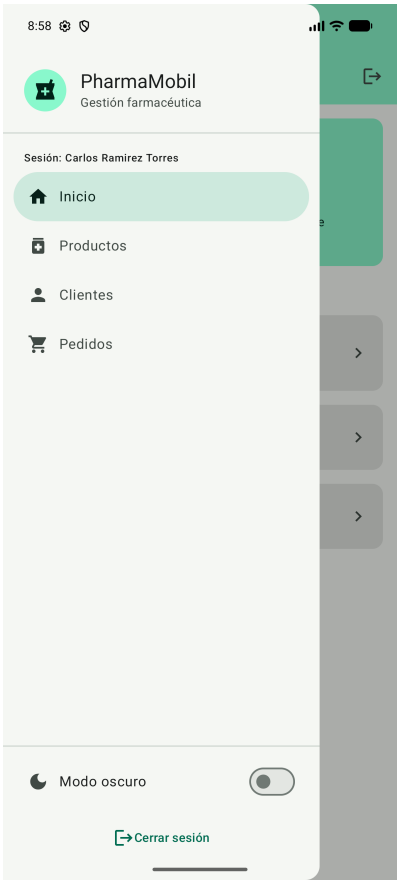
Lectura de la matriz

El backend rechazó con 403 las operaciones fuera del permiso de cada rol. Los códigos provienen de peticiones directas autenticadas; la oferta de acciones se observó en Android. El vendedor ve productos en modo consulta; almacén no ve Clientes ni Pedidos. Clientes utiliza el repositorio en memoria de esta versión académica. Registrar venta y Reportes aún no cuentan con pantallas funcionales.

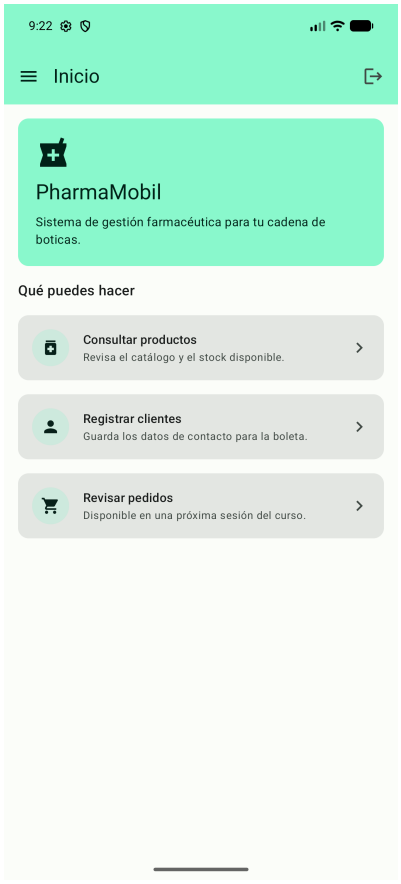
Corrección de interfaz

La portada del vendedor ahora dice Consultar productos y explica que puede revisar catálogo y stock. Commit 2c787d0.

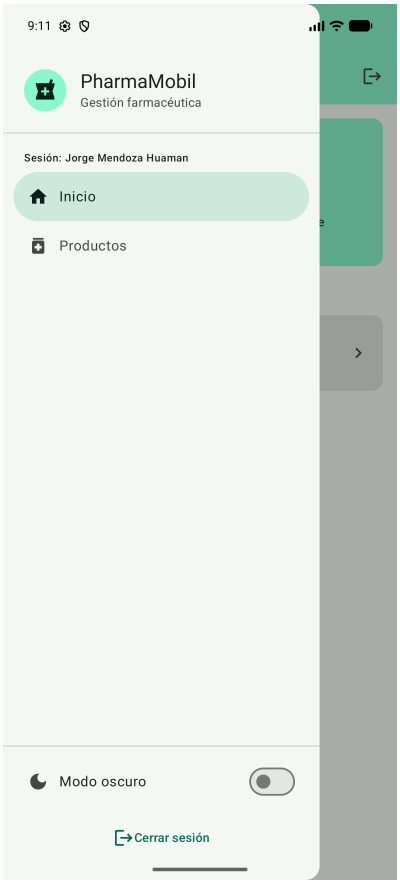
5.1 Evidencia visual por rol



admin



vendedor



almacen

Evidencia adicional: A_perm_vendedor_productos.png muestra inventario sin formulario, editar ni eliminar; A_perm_almacen_productos.png muestra el formulario de registro autorizado.

6. Hallazgos, correcciones y conclusiones

Hallazgos

• El evento global de sesión se emitía con tryEmit y podía perderse; se cambió a emit para garantizar la redirección.

• La portada del vendedor decía Registrar productos aunque el formulario estaba oculto; se cambió a Consultar productos.

• Registrar venta y Reportes todavía no tienen una pantalla funcional en esta versión de la app.

• Sin hallazgos de acciones realmente ejecutables que la UI ofrezca y el servidor rechace con 403.

Commits de la actividad

Hash	Mensaje
`507da07`	fix(auth): asegurar redireccion al expirar la sesion
`9c84377`	test(auth): agregar utilidad debug para alterar token
`2c787d0`	fix(auth): ajustar acceso de productos segun permiso
`08b05ef`	test(auth): verificar cliente real tras cerrar sesion

Conclusiones

• La sesión debe invalidarse ante cualquier 401 asociado al JWT para evitar una interfaz aparentemente autenticada.

• El almacenamiento cifrado y el saneamiento de logs reducen la exposición del token en un dispositivo de desarrollo.

• La autorización del backend sigue siendo la fuente de verdad; la UI usa los permisos para evitar acciones imposibles.

• Para la sesión 11, las operaciones offline deberán distinguir datos en caché de una sesión vencida y exigir nueva autenticación antes de sincronizar.

7. Control de evidencias

Archivo	Estado
A_esc1_valido_servidor.png	Obtenida
A_esc1_valido_pantalla.png	Obtenida
A_esc2_expirado_servidor.png	Obtenida
A_esc2_expirado_pantalla.png	Obtenida
A_esc3_alterado_servidor.png	Obtenida
A_esc3_alterado_pantalla.png	Obtenida
A_esc4_sin_cabecera_servidor.png	Obtenida
A_esc4_sin_cabecera_pantalla.png	Obtenida
A_esc5_prefijo_servidor.png	Obtenida
A_esc5_prefijo_pantalla.png	Obtenida
A_esc6_deshabilitado_servidor.png	Obtenida
A_esc6_deshabilitado_pantalla.png	Obtenida
A_alm1_archivo_cifrado.png	Obtenida
A_alm2_logcat_saneado.png	Obtenida
A_alm3_sesion_persiste.png	Obtenida
A_cierre1_almacen_vacio.png	Obtenida
A_cierre2_cliente_sin_token.png	Obtenida
A_cierre3_login_limpio.png	Obtenida
A_cierre4_atras_bloqueado.png	Obtenida
A_perm_admin.png	Obtenida
A_perm_vendedor.png	Obtenida
A_perm_almacen.png	Obtenida

Estado de entrega

Se obtuvieron las 22 capturas principales solicitadas: 12 de escenarios, 3 de almacenamiento, 4 de cierre y 3 de roles. Hay 3 capturas adicionales. Se verificó la restauración a 60 minutos y los tres usuarios activos. iOS quedó fuera del alcance indicado. Los commits de la actividad están publicados y verificados en la rama remota.

Repositorio y rama

https://github.com/123456jor/pharmaMobile-/tree/feature/auth-jwt-quispe

8. Lista de cotejo previa a la entrega

N.º	Criterio observable	Estado
1	PDF con el nombre S10_ActividadAutonoma_Quispe.pdf.	Sí
2	Portada con nombre completo, sesión, fecha y enlace a la rama.	Sí
3	Seis escenarios con sus capturas respectivas.	Sí
4	Código HTTP y message literal en cada escenario (200 no contiene message de error).	Sí
5	Expiración detectada y navegación al login documentadas.	Sí
6	Evidencia del archivo cifrado sin JWT legible.	Sí
7	Captura de Logcat con Authorization saneada.	Sí
8	Cuatro efectos del logout verificados, incluido el cliente HTTP real.	Sí
9	Matriz de seis operaciones y tres usuarios con HTTP y oferta de UI.	Sí
10	Expiración restaurada a 60 minutos y usuarios reactivados.	Sí
11	Commits de la actividad accesibles en la rama remota del enlace entregado.	Sí

Notas de ejecución

• Las seis respuestas de servidor se repitieron en Postman y sus capturas originales se guardaron con los nombres solicitados. Los resultados iniciales HTTP/JSON también se conservaron.
• Las capturas de Android se obtuvieron del emulador Pixel 8 Pro mediante adb screencap. Los archivos y logs de ADB se mostraron sin modificaciones en Bloc de notas para las capturas de almacenamiento y caché; no se presentan como terminal o Device Explorer.
• Las horas de la bitácora son del equipo local (UTC-05:00). Las repeticiones en Postman tienen su propia hora visible; Logcat refleja el reloj UTC del emulador.
• La matriz HTTP se ejecutó mediante solicitudes directas autenticadas; la observación de acciones de UI se hizo en Android. Clientes usa el repositorio en memoria de la versión académica. Registrar ventas y Reportes no tienen pantalla funcional.
• iOS no se verificó por indicación del usuario y ausencia de macOS/Xcode.
• El usuario autorizó el push el 15/10/2026. Se publicó la actividad en feature/auth-jwt-quispe y git ls-remote confirmó el commit de evidencias 171afd3b074e696159d0133d4e40847cc7f199ab.